

INCIDENT REPORT

CATBOMBER Data Exfiltration & System Reconnaissance

Date of Investigation: 2026-8-20	Severity: Critical
Analyst: Omar AbdelKader	Incident Type: Malware / Exfiltration / Reconnaissance

Executive Summary

Network traffic analysis identified a critical security breach resulting in the unauthorized exfiltration of sensitive Personally Identifiable Information (PII), financial data, and critical Active Directory reconnaissance data. The threat actor leveraged unencrypted HTTP channels to transmit compromised emails, passwords, credit cards, and local domain configurations to an external malicious server. The presence of downloaded malicious executables and deprecated encryption protocols highlights significant security posture vulnerabilities requiring immediate remediation.

Investigation Methodology

- 1. Protocol Anomaly Detection:** Initial network sweeps identified the active use of TLSv1. The presence of this deprecated protocol served as a primary indicator of a vulnerable internal network posture.
- 2. DNS Traffic Review:** Threat hunting within DNS logs revealed suspicious lookups for "whatismyip." This behavior is a common tactic used by automated malware to identify a compromised host's public-facing IP address for staging.
- 3. HTTP Stream Analysis:** A pivot to unencrypted HTTP traffic uncovered a high volume of outbound POST requests. These requests were directed at an external IP address lacking a standard domain resolution.
- 4. Threat Intelligence Correlation:** The destination IP address was extracted and cross-referenced with VirusTotal. Multiple vendors classified the IP as a known malicious node, confirming an active compromise.
- 5. Payload Decapsulation & PII Exfiltration:** Deep packet inspection of the initial POST payloads revealed the destination server utilized the unusual header "cowboy." The payloads contained plaintext exfiltration of user credentials and credit card data.
- 6. Malware Execution & Active Directory Reconnaissance:** Further inspection of the final HTTP POST requests linked to downloaded .exe payloads revealed automated system discovery. Analysis confirmed the execution of commands such as `nltest /domain_trusts /all_trusts`. The attacker successfully exfiltrated comprehensive local machine and domain data back to the "cowboy" server, including:
 - Compromised Host & User:** CAT-BOMB-W7-PC logged in as Phillip Ghent.
 - Domain Configuration:** Forest and Domain Controller details for catbomber.net (Catbomber-DC.catbomber.net).
 - Enumerated Accounts:** Extracted domain usernames including Administrator, Guest, krbtgt, and timothy.sizemore.
 - Enumerated Hosts:** Discovered network endpoints including CAT-BOMB-W10-PC and Catbomber-DC.

Indicators of Compromise & Mitigation

- **Behavioral IOC:** Automated and repetitive DNS queries for external IP verification (whatismyip).
- **Network IOC:** HTTP POST requests routing to the identified malicious IP utilizing the "cowboy" server header.
- **Host IOC:** Execution of nltest and other automated domain trust discovery commands by suspicious downloaded .exe files.
- **Mitigation 1 (Containment):** Immediately isolate CAT-BOMB-W7-PC and any other enumerated hosts from the network, and block the malicious destination IP at the perimeter firewall.
- **Mitigation 2 (Identity & Credential Remediation):** Initiate an immediate password reset for all compromised accounts, prioritizing Phillip Ghent, timothy.sizemore, and Domain Admin accounts, especially verifying the integrity of the krbtgt account.
- **Mitigation 3 (Network Hardening):** Enforce TLS 1.2 or higher globally, block TLSv1, and mandate HTTPS for all data transmissions to prevent plaintext packet sniffing.